

07 · CONDICIONES DE CONFIANZA

Privacidad y seguridad

Anima trabaja con información vinculada al bienestar emocional. El piloto debe proteger a cada persona y, al mismo tiempo, producir indicadores útiles para la gestión pública.

La confianza se diseña antes de recibir datos reales.

El Municipio debe aprobar la finalidad, los responsables, el circuito de consentimiento, los accesos y la respuesta ante incidentes. Sin esas definiciones, el piloto permanece en un entorno de demostración.

Base local

Datos personales y de salud.
Finalidad, consentimiento y seguridad.

Alineamiento HIPAA

Evaluación de riesgos y salvaguardas
administrativas, físicas y técnicas.

Ruta ISO 27001

Gestión de seguridad,
controles, evidencia y auditoría.

Seis compromisos que no se negocian

1

Finalidad definida

Cada dato responde a una finalidad aprobada. No se reutiliza por conveniencia.

2

Consentimiento verificable

La persona entiende qué se registra, para qué, por cuánto tiempo y cómo revocarlo.

3

Identidades separadas

Los datos identificatorios se guardan fuera del repositorio analítico y con acceso restringido.

4

Lectura agregada

El tablero municipal muestra grupos y zonas que superan un umbral mínimo. No expone casos.

5

Acceso trazable

Cada consulta, cambio y exportación queda asociada a una persona, un rol y una fecha.

6

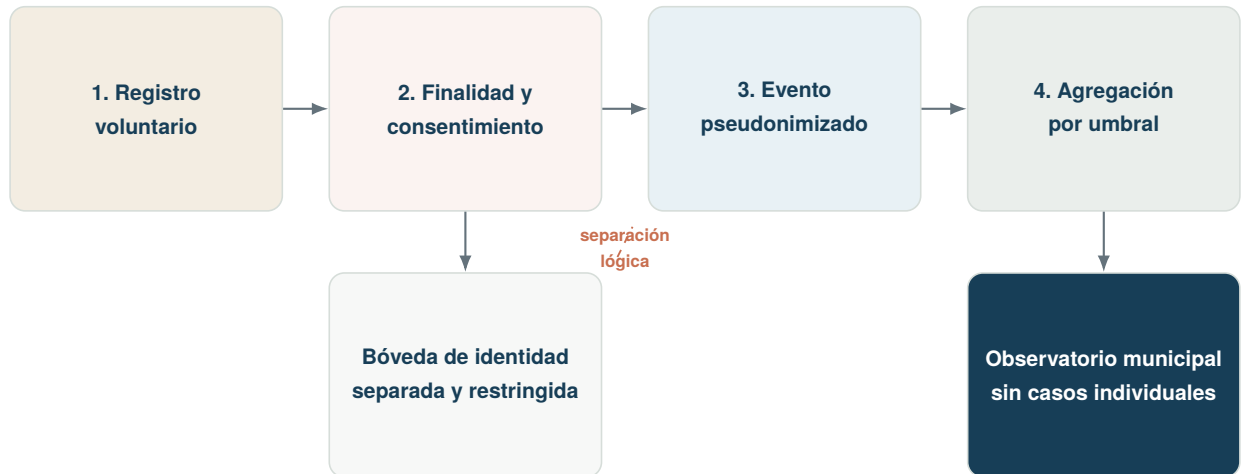
Respuesta humana

La aplicación no diagnostica. Un equipo competente define y opera los protocolos de ayuda.

07.1 · ARQUITECTURA DE CONFIANZA

Cómo se protege el dato

La protección no depende de una sola base de datos. Depende de separar identidades, limitar los usos y evitar que el observatorio municipal pueda reconstruir historias individuales.



Regla del observatorio

El tablero sólo recibe indicadores agregados. Si una combinación de zona, período y grupo no alcanza el umbral acordado, el sistema no muestra el resultado ni permite exportarlo.

Recolección

- Sólo campos aprobados.
- Aviso de privacidad claro.
- Consentimiento con versión y fecha.
- Revocación y canal de consulta.

Custodia

- Cifrado en tránsito y reposo.
- Acceso por rol y MFA.
- Copias y restauración probada.
- Retención y eliminación definidas.

Uso y control

- Registro de accesos y exportaciones.
- Revisión periódica de permisos.
- Monitoreo de incidentes.
- Proveedores sujetos a contrato.

Pruebas antes de habilitar datos reales

Separación

La vinculación con una identidad exige una función autorizada.

Supresión

Los grupos bajo el umbral no se muestran ni se exportan.

Trazabilidad

Cada acceso y exportación deja un registro auditable.

Recuperación

Una copia se restaura en una prueba aislada y documentada.

07.2 · GOBERNANZA OPERATIVA

Quién decide y quién responde

La seguridad falla cuando una tarea queda sin dueño. El convenio del piloto debe asignar responsabilidades institucionales, técnicas y de cuidado antes de habilitar datos reales.

MUNICIPIO

Finalidad y decisión pública

Aprueba el propósito, los perfiles habilitados, la retención y el protocolo institucional de respuesta.

EQUIPO ANIMA

Tecnología y operación

Implementa los controles, conserva la evidencia técnica y comunica incidentes según el acuerdo.

EQUIPO INTERDISCIPLINARIO

Criterio de cuidado

Define lenguaje, umbrales y rutas de ayuda. La plataforma no reemplaza su evaluación profesional.

Matriz mínima de responsabilidades

Decisión o tarea	Municipio	Anima	Equipo de cuidado
Finalidad y base de tratamiento	Aprueba	Documenta	Revisa
Umbral de agregación	Aprueba	Implementa	Recomienda
Perfiles y exportaciones	Aprueba	Configura	Consulta
Retención y eliminación	Aprueba	Ejecuta	Consulta
Incidente de seguridad	Decide comunicación	Contiene e informa	Evalúa impacto asistencial
Ruta de ayuda	Habilita capacidad	Integra el canal	Define y opera

Circuito de incidentes

1 · DETECTAR

Alerta y registro

2 · CONTENER

Limitar el daño

3 · EVALUAR

Datos y personas

4 · COMUNICAR

Autoridad y afectados

5 · CERRAR

Corregir y aprender

Cierre contractual antes del piloto

El convenio debe nombrar responsables, contactos de incidentes, retención, umbral de agregación, permisos de exportación y capacidad de respuesta humana para cada conjunto de datos.

07.3 · REFERENCIA INTERNACIONAL

Plan de alineamiento HIPAA

HIPAA sólo corresponde si interviene una entidad cubierta o un asociado de negocio alcanzado por la normativa estadounidense. Esa aplicabilidad se determina antes de hablar de cumplimiento.

H

Estado propuesto: preparación y evidencia

Si HIPAA no resulta aplicable, el paquete de salvaguardas se conserva como referencia de seguridad para datos de salud.

1

Aplicabilidad y alcance

Identificar entidades, flujos, datos protegidos, proveedores y contratos. Emitir una conclusión jurídica documentada.

4

Salvaguardas físicas y técnicas

Proteger equipos y medios. Aplicar identidad única, MFA, mínimo privilegio, cifrado, auditoría, integridad y recuperación.

2

Riesgo y responsabilidad

Designar un responsable de seguridad. Inventariar activos y evaluar amenazas sobre confidencialidad, integridad y disponibilidad.

5

Proveedores y acuerdos

Evaluar nube, mensajería y soporte. Incorporar obligaciones de seguridad y, si corresponde, acuerdos de asociado de negocio.

3

Salvaguardas administrativas

Aprobar políticas, altas y bajas de acceso, capacitación, continuidad, revisión periódica y régimen de excepciones.

6

Incidentes y evidencia

Definir detección, contención, evaluación, comunicación y cierre. Probar el circuito y conservar los registros.

Criterios de salida

- Dictamen de aplicabilidad aprobado.
- Registro de riesgos con responsables.
- Matriz de controles y excepciones.
- Contratos y políticas vigentes.
- Restauración de copias verificada.
- Simulacro de incidente documentado.

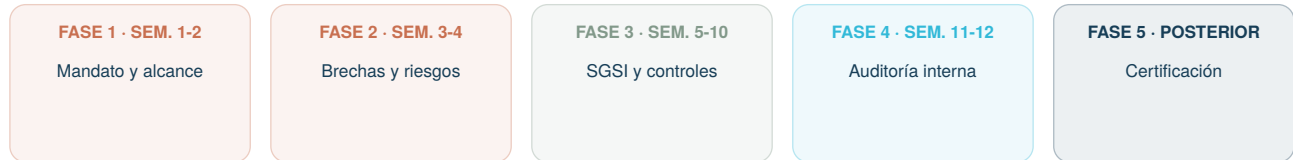
Declaración permitida en esta etapa

Anima adopta un plan de alineamiento basado en la HIPAA Security Rule. No corresponde afirmar que el producto o el Municipio ya cumplen HIPAA.

07.4 · SISTEMA DE GESTIÓN

Ruta ISO/IEC 27001:2022

La norma exige un sistema de gestión de seguridad de la información. La certificación llega después de definir el alcance, operar los controles, reunir evidencia y superar una auditoría independiente.



Cronograma de referencia. Se confirma cuando estén definidos el alcance, los proveedores y las integraciones del piloto.

Trabajo y evidencia por fase

Fase	Trabajo	Evidencia de cierre
1. Alcance	Confirmar objetivos, roles, sedes, sistemas, datos y terceros.	Alcance del SGSI y responsables aprobados.
2. Riesgos	Definir el método, valorar riesgos y priorizar tratamientos.	Informe de brechas y registro de riesgos.
3. Implementación	Aprobar políticas, seleccionar controles y operar los procedimientos.	Declaración de aplicabilidad y registros de operación.
4. Verificación	Medir, auditar internamente, corregir y revisar con la dirección.	Informe de auditoría, acciones y acta de revisión.
5. Certificación	Contratar un organismo acreditado y atender sus hallazgos.	Resultado de auditoría y certificado, si corresponde.

Paquete documental

- Política de seguridad y alcance.
- Método y registro de riesgos.
- Declaración de aplicabilidad.
- Gestión de accesos y proveedores.
- Continuidad y respuesta a incidentes.
- Auditoría y revisión de dirección.

Puerta de ingreso al piloto

- Datos y finalidades aprobados.
- Riesgos altos tratados o aceptados.
- MFA, permisos y registros probados.
- Restauración de copias verificada.
- Protocolo de incidentes ensayado.
- Responsable de cada control designado.

Cómo se convierte esto en un presupuesto defendible

Se cotizan diagnóstico, arquitectura, controles, documentación, pruebas y auditoría como entregables verificables. La seguridad no debe aparecer como una suma genérica sin alcance.

Fuentes oficiales: Ley 25.326; Ley 26.657; Resolución AAIP 47/2018; HHS, HIPAA Security Rule; HHS, aplicabilidad; ISO/IEC 27001:2022. Referencia visual: Ato / Heyato.